

A privacy impact assessment (PIA) is a process which assists organizations in identifying and managing the privacy risks arising from new projects, initiatives, systems, processes, strategies, policies, business relationships etc. It benefits various stakeholders, including the organization itself and the customers, in many ways. In the United States and Europe, policies have been issued to mandate and standardize privacy impact assessments.

Overview

A privacy impact assessment is a type of impact assessment conducted by an organization (typically, a government agency or corporation with access to a large amount of sensitive, private data about individuals in or flowing through its system). The organization reviews its own processes to determine how these processes affect or might compromise the privacy of the individuals whose data it holds, collects, or processes. PIAs have been conducted by various sub-agencies of the U.S. Department of Homeland Security (DHS), and methods to conduct them have been standardized.

A PIA is typically designed to accomplish three main goals:

Ensure conformance with applicable legal, regulatory, and policy requirements for privacy.

Identify and evaluate the risks of privacy breaches or other incidents and effects.

Identify appropriate privacy controls to mitigate unacceptable risks.

A privacy impact report seeks to identify and record the essential components of any proposed system containing significant amounts of personal information and to establish how the privacy risks associated with that system can be managed. A PIA will sometimes go beyond an assessment of a "system" and consider critical "downstream" effects on people who are affected in some way by the proposal.

Purpose

Since PIA concerns an organization's ability to keep private information safe, the PIA should be completed whenever said organization is in possession of the personal information on its employees, clients, customers and business contacts etc. Although legal definitions vary, personal information typically includes a person's: name, age, telephone number, email address, sex, health information. A PIA should also be conducted whenever the organization possesses information that is otherwise sensitive, or if the security controls systems protecting private or sensitive information are undergoing changes that could lead to privacy incidents.

Benefits

According to a presentation at the International Association of Privacy Professionals Congress, a PIA has the following benefits:

Provides an early warning system - a way to detect privacy problems, build safeguards before, not after, heavy investment, and to fix privacy problems sooner rather than later

Avoids costly or embarrassing privacy mistakes

Provides evidence that an organization attempted to prevent privacy risks (reduce liability, negative publicity, damage to reputation)

Enhances informed decision-making

Helps the organization gain the public's trust and confidence

Demonstrates to employees, contractors, customers, citizens that the organization takes privacy seriously

Implementation

PIAs involve a simple process:

Project Initiation: define the scope of the PIA process (which varies by organization and project). If the project is in its early stages, the organization may choose to do a Preliminary PIA, and then complete a full PIA once it is fully under way.

Data Flow Analysis: mapping out how the proposed business process handles personal information, identifying clusters of personal information, and creating a diagram of how the personal information flows through the organization as a result of the business activities in question.

Privacy Analysis: personnel involved with the movement of personal information may complete privacy analysis questionnaires, followed by reviews, interviews and discussions of the privacy issues and implications.

Privacy Impact Assessment Report: the privacy risks and potential implications are documented, as well as a discussion of possible efforts that could be made in order to mitigate or remedy the risks.

History

In the 1970s, the Technology Assessment (TA) was created by the United States Office of Technology Assessment. A TA was used to determine the societal and social repercussions of new technologies. Similarly, at around this time came the environmental impact assessments (EIA), a reaction to the social push from the sixties Green movements. The method of both of these impact assessments acted as precursors to the creation of the PIA.

The "Privacy Impact Statement" was a much less extensive version of the PIA that came about in the late eighties. During the 1990s there became a need to measure the effectiveness of a company or organization's data security, especially with most data now being stored on computers or other electronic platforms. More extensive PIAs started to be used more frequently by corporations and governments in the mid-1990s, and now are used by organizations all around the world, and by several governments including, New Zealand,

Canada, Australia, and the United States Department of Homeland Security to assess privacy risk of their systems. In addition several other countries and corporations use assessment systems similar to PIAs for data risk analysis.

PIA Worldwide

United States

The E-Government Act of 2002, Section 208, established the requirement for agencies to conduct PIAs for electronic information systems and collections. The assessment is a practical method of evaluating privacy in information systems and collections, and documented assurance that privacy issues have been identified and adequately addressed. The process is designed to guide SEC system owners and developers in assessing privacy during the early stages of development and throughout the systems development life cycle (SDLC), to determine how their project will affect the privacy of individuals and whether the project objectives can be met while also protecting privacy.

Europe

The European Commission signed its first Framework for Privacy Impact Assessments in the context of RFID Technology in 2011. This served as a basis to later recognize PIAs in the General Data Protection Regulation (GDPR), which in some cases now mandates data protection impact assessment (DPIA). Aside from new IT systems and projects, the PIA approach has value for structured, periodic reviews or audits of an organization's privacy arrangements.

PIAF (A Privacy Impact Assessment Framework for data protection and privacy rights) is a European Commission co-funded project that aims to encourage the EU and its Member States to adopt a progressive privacy impact assessment policy as a means of addressing needs and challenges related to privacy and to the processing of personal data.

See also

Global surveillance

Mass surveillance

Human rights in cyberspace

Information ethics

Information privacy

Penetration test

== References ==